Comprehensive SOC and Network Security Operations Lab Implementation

1. SOC Fundamentals

A Security Operations Center (SOC) is basically the security control room of an organization. It is the place where a dedicated team continuously monitors systems, networks, and user activity to detect and respond to cyber threats.

The main purpose of a SOC is not just reacting to attacks, but detecting them early before they cause serious damage. Instead of waiting for something bad to happen, SOC teams monitor logs, alerts, and network traffic 24/7.

SOC is responsible for:

- Watching all security alerts
- Investigating suspicious activities
- Stopping attacks
- Reducing risk
- Protecting company data

Purpose of SOC

The main goals of a SOC are:

First, continuous monitoring. Systems generate thousands of logs every day. The SOC team monitors these logs in real time using tools like SIEM.

Second, threat detection. The team identifies activities such as brute-force login attempts, malware infections, suspicious file downloads, or unauthorized access.

Third, incident response. When something malicious is confirmed, action is taken immediately. For example, blocking an IP address, isolating a compromised system, or disabling a user account.

Fourth, risk reduction. The faster a threat is detected, the less damage it can cause.

SOC Team Structure

A SOC usually works in levels.

1. Tier 1 analysts are the first line of defense. They monitor dashboards and check alerts. If something looks serious, they escalate it.

2. Tier 2 analysts perform deeper investigations. They analyze logs, check indicators of compromise, and confirm whether it is a real attack.

3. Tier 3 analysts are advanced experts. They do threat hunting and create detection rules. They study attacker behavior and improve security monitoring.

4. There is also a SOC manager who supervises operations and coordinates during major incidents.

What a SOC Actually Does Daily

On a daily basis, a SOC team:

- Monitors SIEM dashboards
- Investigates alerts
- Reviews failed login attempts
- Checks suspicious IP activity
- Correlates logs from different systems
- Documents incidents
- Updates detection rules
- It is a continuous process.

Tools Used in SOC

1. SOC teams use multiple tools, such as:
2. SIEM tools (like Elastic or Splunk) to collect and analyze logs.
3. IDS tools (like Snort) to detect suspicious network traffic.
4. EDR tools to monitor endpoint behavior.
5. Threat intelligence feeds to identify known malicious IPs and domains.
6. These tools work together to provide full visibility.

SOC Workflow

- When an alert is generated, the workflow generally looks like this:
- Alert is triggered.
- Analyst checks the alert.
- Logs are analyzed.
- Suspicious activity is validated.
- If confirmed, action is taken.
- Incident is documented.
- Lessons are recorded for improvement.
- This structured approach ensures no alert is ignored.

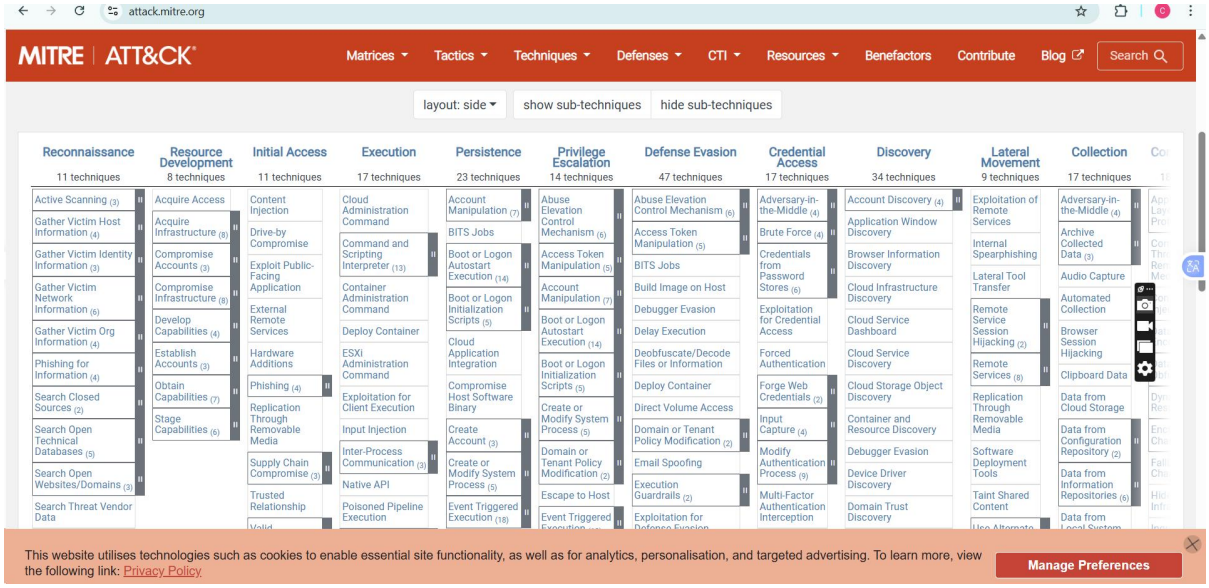
Why SOC Is Important

In today's environment, cyber attacks are very common. Without continuous monitoring, attacks may go unnoticed for days or weeks.

A SOC reduces detection time and response time. This protects sensitive information and ensures business continuity.

It is a critical part of any modern organization's cybersecurity strategy.

Analyzing and learning about mitt&re Attack framework



2. Security Monitoring Basics

Security monitoring is the process of continuously observing systems, networks, and user activities to detect suspicious behavior or security threats.

In simple words, it means watching everything that happens inside a network so that if something unusual happens, it can be detected immediately.

Security monitoring is not only about finding attacks. It is also about identifying abnormal behavior before it becomes a serious problem.

Purpose of Security Monitoring

The main objectives are:

First, detecting unauthorized access.
If someone tries to log in without permission or attempts multiple failed logins, monitoring tools should detect it.

Second, identifying anomalies.
For example, if a normal user suddenly downloads large amounts of data at midnight, that behavior is suspicious.

Third, detecting malware or malicious activity.
Monitoring tools help identify unusual processes, network connections, or unknown file changes.

Fourth, ensuring policy compliance.
Organizations have security policies. Monitoring ensures those rules are followed.

What is Monitored?

1. Security monitoring covers multiple areas:

2. Authentication logs (login attempts)

3. Network traffic (incoming and outgoing connections)

4. System logs

5. Application logs

6. File integrity changes

7. Endpoint processes

1. Firewall activity

Everything generates logs, and monitoring focuses on analyzing those logs.

Key Security Monitoring Tools
1. SIEM (Security Information and Event Management)

- Elastic
- Splunk
- QRadar

SIEM tools collect logs from different sources and analyze them in one place. They also generate alerts when suspicious activity is detected.

2. Network Monitoring Tools

Wireshark

These tools analyze network traffic and help detect abnormal patterns like port scanning, SYN floods, or data exfiltration.

3. IDS/IPS

Snort

IDS detects suspicious traffic based on rules. IPS can block it automatically.

4. Endpoint Monitoring (EDR)

Monitors processes running on computers and detects suspicious behavior like ransomware activity.

Important Metrics in Security Monitoring

- False Positive

    An alert that looks suspicious but is actually normal behavior.

- False Negative

  When a real attack happens but is not detected.

- MTTD (Mean Time To Detect)

  The time taken to detect a threat after it occurs.

- MTTR (Mean Time To Respond)

  The time taken to respond and contain the threat.

Good monitoring reduces MTTD and MTTR.

How Security Monitoring Works (Basic Flow)

1. Event occurs (e.g., failed login).
2. Log is generated.
3. Log is sent to SIEM.
4. SIEM analyzes it.

If rule matches, alert is triggered.

Analyst investigates the alert.

This cycle continues continuously.

Example of Security Monitoring

- If a user enters wrong password 10 times:
- Event ID 4625 is generated (Windows failed login).

- SIEM detects multiple failed attempts.
- Alert is triggered.
- Analyst checks source IP.
- If suspicious, IP is blocked.
- This is a simple example of monitoring and response.

Why Security Monitoring Is Important

Without monitoring:

- Attacks go unnoticed.
- Data theft may happen silently.
- Malware can spread internally.

With proper monitoring:

- Threats are detected early.
- Damage is minimized.
- Organization remains secure.
- Security Monitoring vs Incident Response
- Monitoring is about detecting suspicious activity.
- Incident response starts after confirmation of attack.

- Monitoring is preventive.
- Response is corrective.

Security monitoring is the foundation of SOC operations. It provides visibility into systems and networks and helps detect threats in real time.

Without monitoring, there is no detection. Without detection, there is no security.

Practical Task: Security Monitoring Lab Implementation

Setting Up Lab Environment with Open-Source Tools (Elastic SIEM)

To implement security monitoring, I set up a small lab environment using open-source tools.

Environment Setup:

1. Ubuntu VM (SIEM Server)

2. Kali Linux (Attack Machine)

3. Windows VM (Target System)

4. Elastic Stack (Elasticsearch + Kibana + Filebeat)

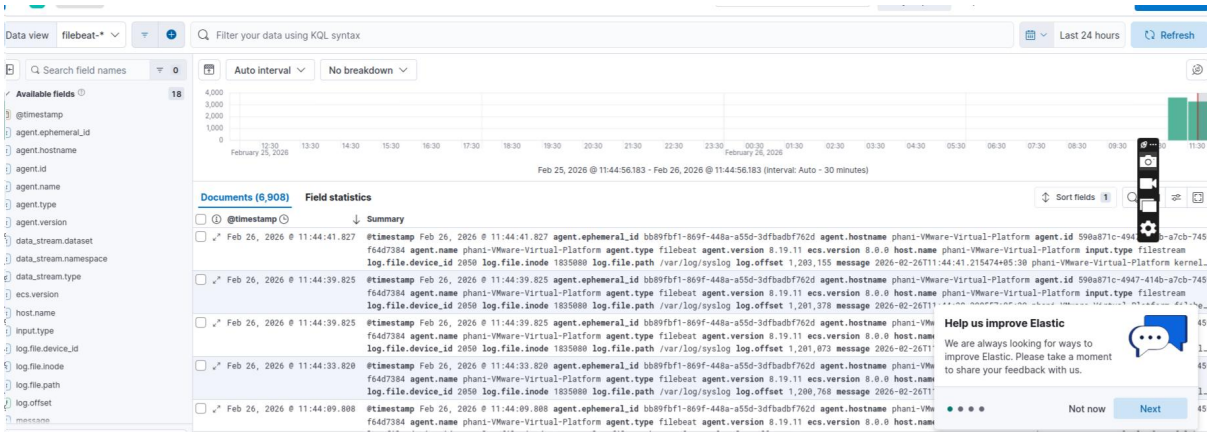
From ubuntu

Starting SIEM tools like elastic search and kibana

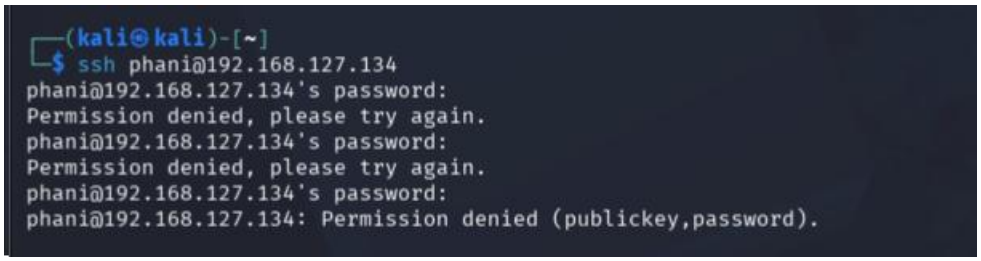
```
phani@phani-VMware-Virtual-Platform:~$ sudo systemctl start elasticsearch
sudo systemctl start kibana
[sudo] password for phani:
phani@phani-VMware-Virtual-Platform:~$ sudo systemctl status elasticsearch
● elasticsearch.service - Elasticsearch
     Loaded: loaded (/usr/lib/systemd/system/elasticsearch.service; enabled; pr>
     Active: active (running) since Thu 2026-02-26 11:02:33 IST; 2min 49s ago
       Docs: https://www.elastic.co
   Main PID: 1722 (java)
      Tasks: 118 (limit: 9378)
     Memory: 4.3G (peak: 4.7G swap: 211.0M swap peak: 211.0M)
        CPU: 3min 48.900s
     CGroup: /system.slice/elasticsearch.service
             ├─1722 /usr/share/elasticsearch/jdk/bin/java -Xms4m -Xmx64m -XX:+U>
             ├─2348 /usr/share/elasticsearch/jdk/bin/java -Des.networkaddress.c>
             └─2491 /usr/share/elasticsearch/modules/x-pack-ml/platform/linux-x>

Feb 26 11:01:29 phani-VMware-Virtual-Platform systemd[1]: Starting elasticsearc>
Feb 26 11:02:33 phani-VMware-Virtual-Platform systemd[1]: Started elasticsearch>
lines 1-15/15 (END)
phani@phani-VMware-Virtual-Platform:~$ sudo systemctl status kibana
● kibana.service - Kibana
     Loaded: loaded (/usr/lib/systemd/system/kibana.service; enabled; preset: e>
     Active: active (running) since Thu 2026-02-26 11:01:29 IST; 4min 4s ago
       Docs: https://www.elastic.co
   Main PID: 1728 (node)
      Tasks: 11 (limit: 9378)
     Memory: 862.4M (peak: 1.1G swap: 2.0M swap peak: 2.1M)
        CPU: 1min 23.228s
     CGroup: /system.slice/kibana.service
             └─1728 /usr/share/kibana/bin/../node/glibc-217/bin/node /usr/share>
```

To check the elastic and kibana and filebeat for this I'm going to collect a failed password login attempt from kali

Step : 1 I opened elastic in my firebox web browser through localhost

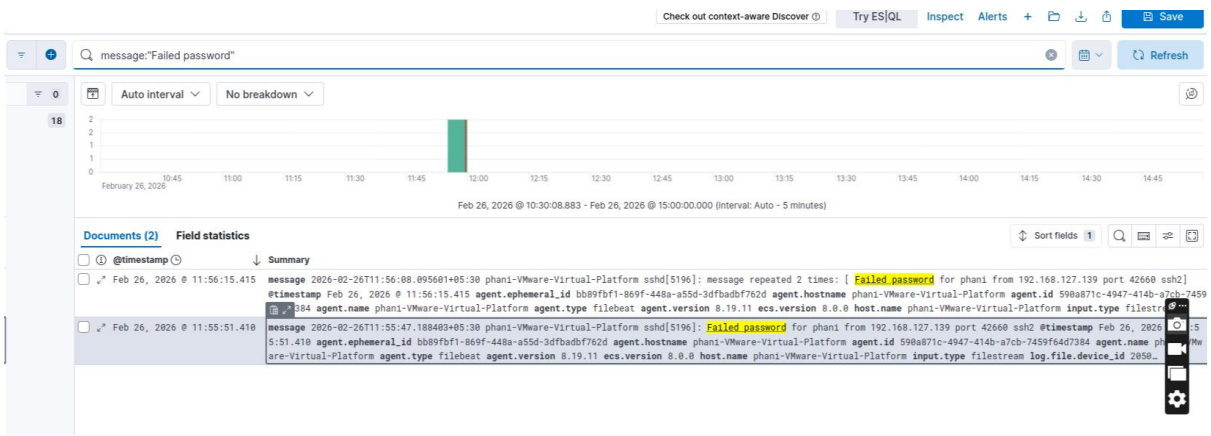


Opening kali linux and performing a failed password login attempt throgh secure shell ssh method

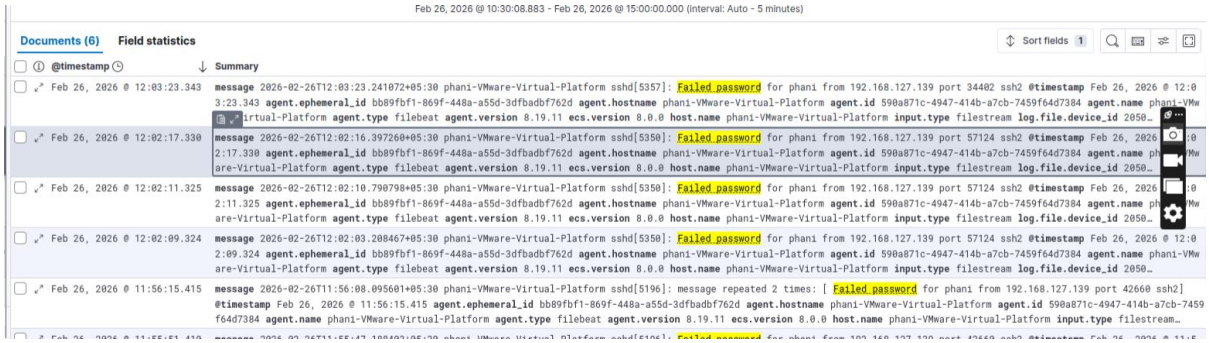


Now opening elastic search and searching for failed password in the kibana dashboard

message: “Failed password”



The elastic search and kibana are working , logs are collected overall good working all softwares and services



Suspicious attack observed due to number of failed passwords login attempts then it could be a bruteforce attack then the soc L1 engineer goes to alert the remaining L2 and L3 engineers about this incident and L2 and L3 engineers takes action .

The soc L1 role works like this……..

2. Log management fundamentals

Every computer and server writes a record of activities. These records are called as logs.

Example :-

- Someone logged in
- Someone entered wriong password
- A file was deleted
- A website was accessed
- A system error happened

All these are stored as logs

Log management means collecting logs ,storing them properly,and checking them to find problems or attacks.

Log Lifecycle (5 Stages)

1. Collection

Collect logs from:

1. Windows machines
2. Linux servers
3. Firewalls
4. Web servers
5. Tool examples:
6. Fluentd
7. Logstash
8. Filebeat

Goal: Bring all logs into one central place (like Elastic SIEM).

3. Normalization

Different systems produce logs in different formats.
Example:

- Windows log looks different
- Apache web log looks different

Normalization means: Convert all logs into a common format (like JSON).

4. Storage

Logs are stored in:

- Elasticsearch
- SIEM

So we can search them later.

5. Retention

How long to keep logs?
1. 30 days
2. 90 days
3. 1 year

Used for:
- Forensics
- Compliance
- Incident investigation

6. Analysis

Search logs to detect:
1. Failed logins
2. Brute-force attacks
3. Suspicious IP
4. Malware activity

Common Log Types

1.Windows Event Logs

Important IDs:
4624 → Successful login
4625 → Failed login
7045 → New service created

2. Syslog (Linux logs)

Location:
/var/log/syslog
/var/log/auth.log

Shows:

- SSH logins
- System errors

User activity

3. HTTP Server Logs (Apache)
Location:

/var/log/apache2/access.log

Shows:

1. Visitor IP
2. Page requested
3. Status code (200, 404)

Practical tasks

Installing fluentd on ubuntu to collect system logs

Update ubuntu by using

```
sudo apt update
```

Install the logstash with this

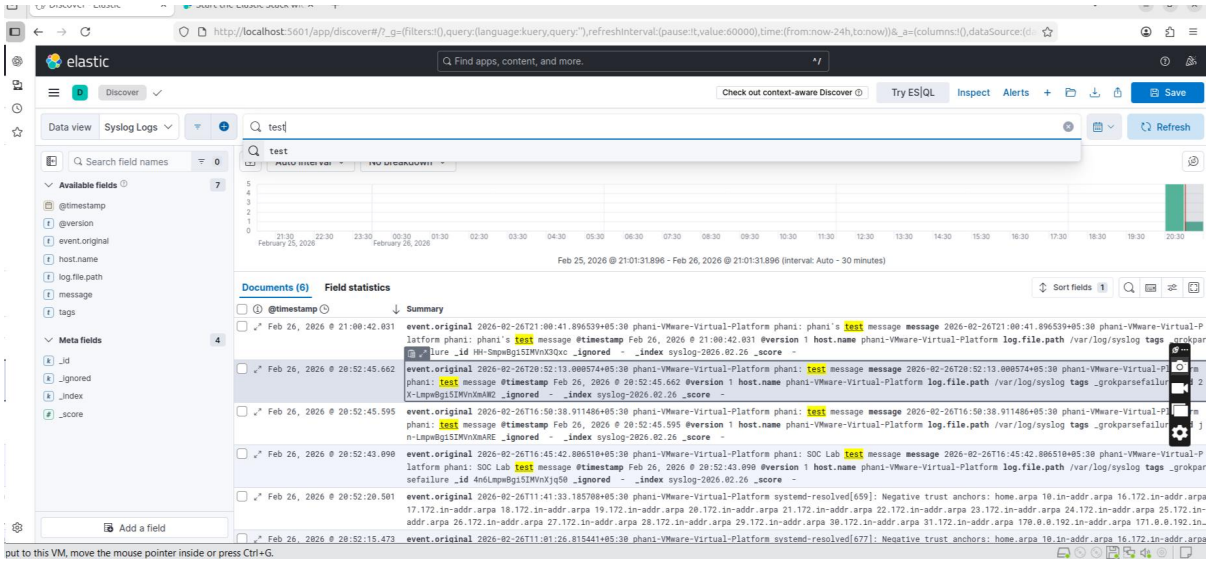
```
sudo apt install logstash
```

Previously, I have installed the logstash in my ubuntu machine . so , I'm opening it and checking the status by using

```
sudo systemctl status logstash
```

```
phani@phani-VMware-Virtual-Platform:~$ sudo systemctl status logstash
[sudo] password for phani:
○ logstash.service - logstash
     Loaded: loaded (/usr/lib/systemd/system/logstash.service; disabled; preset>
     Active: inactive (dead)
lines 1-3/3 (END)
phani@phani-VMware-Virtual-Platform:~$ sudo systemctl start logstash
phani@phani-VMware-Virtual-Platform:~$ sudo systemctl status logstash
● logstash.service - logstash
     Loaded: loaded (/usr/lib/systemd/system/logstash.service; disabled; preset>
     Active: active (running) since Thu 2026-02-26 16:32:42 IST; 2s ago
   Main PID: 6988 (java)
      Tasks: 19 (limit: 9378)
     Memory: 151.8M (peak: 151.8M)
        CPU: 3.549s
     CGroup: /system.slice/logstash.service
             └─6988 /usr/share/logstash/jdk/bin/java -Xms1g -Xmx1g -Djava.awt.h>

Feb 26 16:32:42 phani-VMware-Virtual-Platform systemd[1]: Started logstash.serv>
Feb 26 16:32:42 phani-VMware-Virtual-Platform logstash[6988]: Using bundled JDK>
lines 1-12/12 (END)
```

- Now I'm going to colecting logs from elasstic search from logstash
- I'm creating some logs by using logger "test message"
- For this, I'm creating a data view name called syslog logs and index is syslog-* and going to tap create data view
- After all this configuration going to search with test message on KQL syntax to retreive how many messages are stored in the logstash

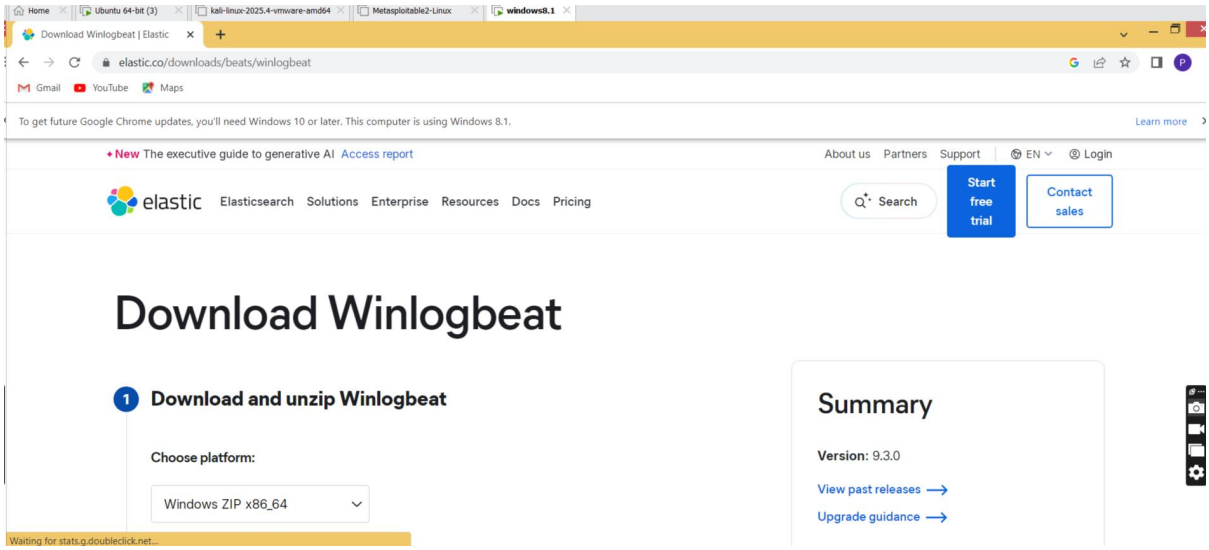


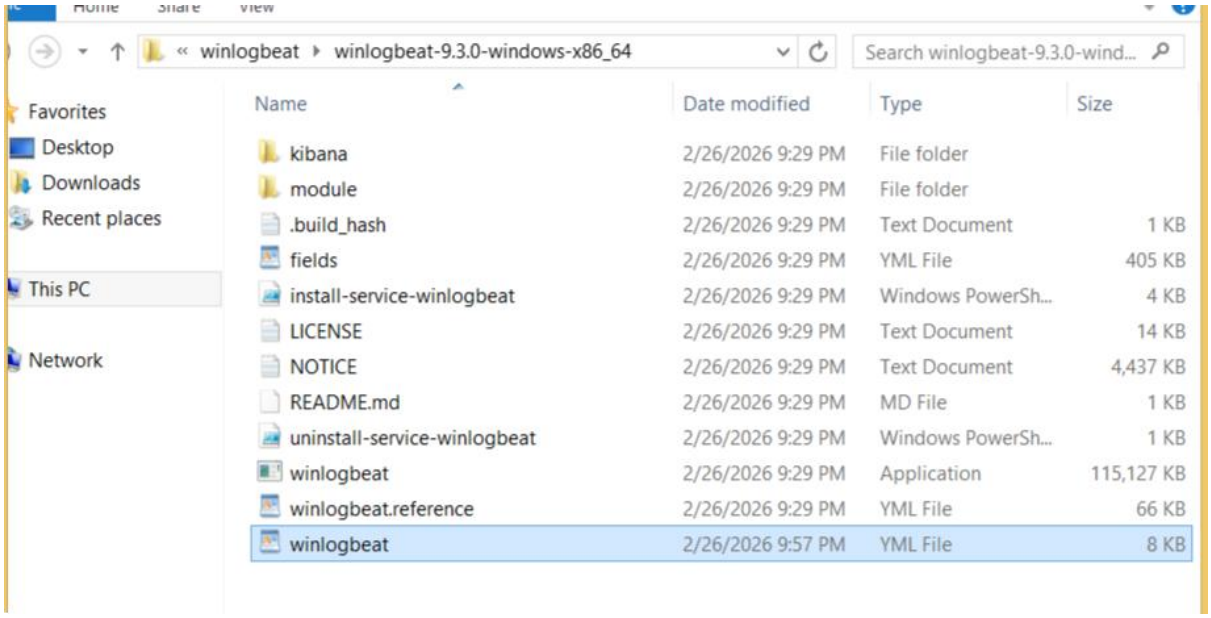
Logs successfully collected from syslog and visualized in kibana usinmg Data View syslog-*

Log lifecycle

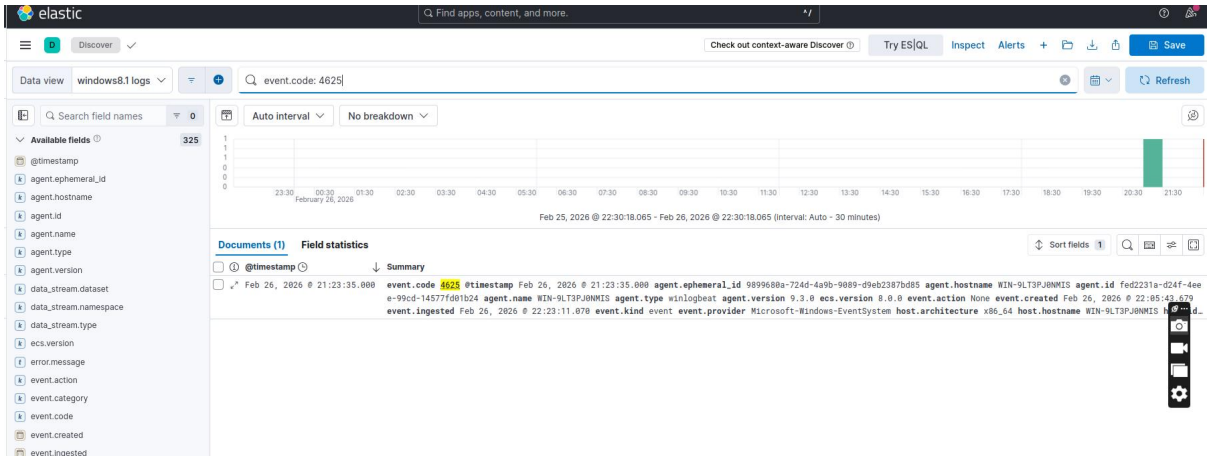
1. Collection -> Logstash
2. Storage -> Elasticsearch
3. Visualization -> KQL queries

To perform KQL query to find event 4625 there is no winlogbeat downloaded in my windows vm. so for this, I'm downloading it from chrome browser





I have configured the winlogbeat and that is working properly and I have searched to retrive windows event of 4625 which is failed login attempts



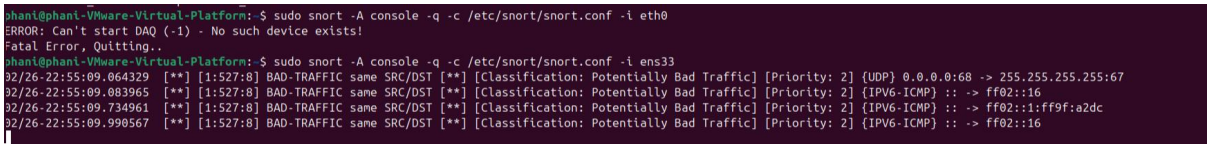
To save the output from apache foramt to JSON format then this command can do that operation

curl -X GET "http://localhost:9200/winlogbeat-*/_search?pretty" > logs.json

4. Security Tools Overview

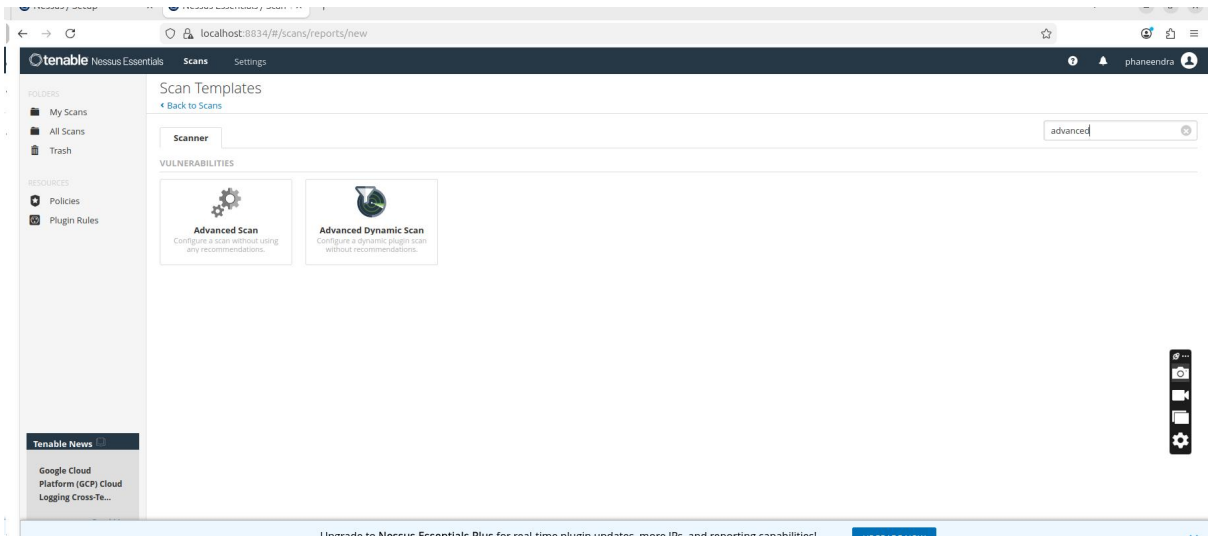
Snort

- Opening snort mode and adding rule in the snort.rules file and then executing the snort in IDS mode.
- Opening kali linux and testing the IDS with curl http://malicious.com

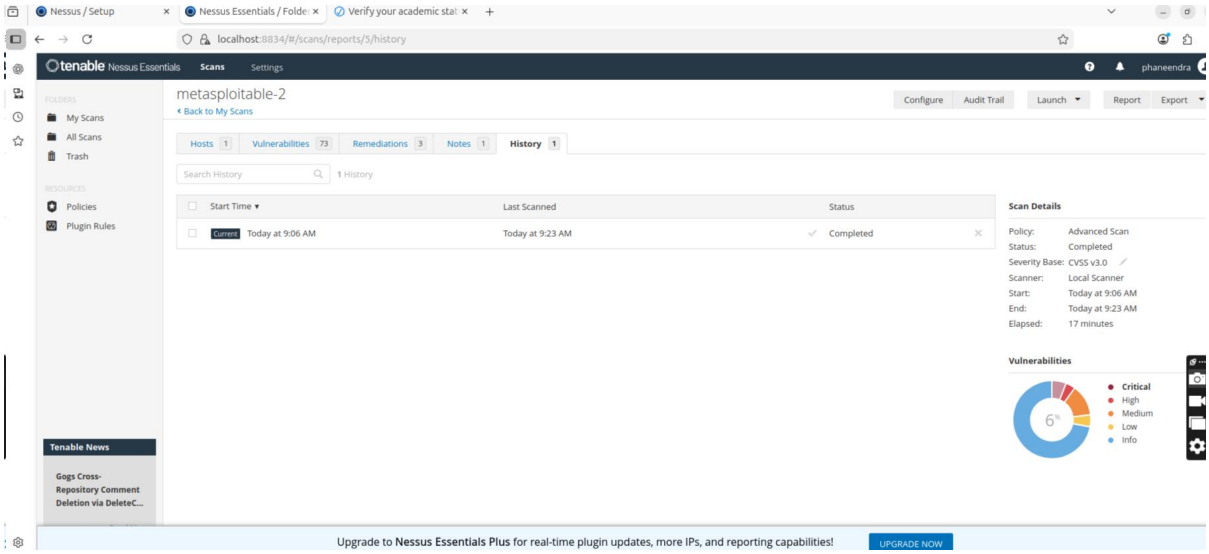


Vulnerabilty scanning through nessus

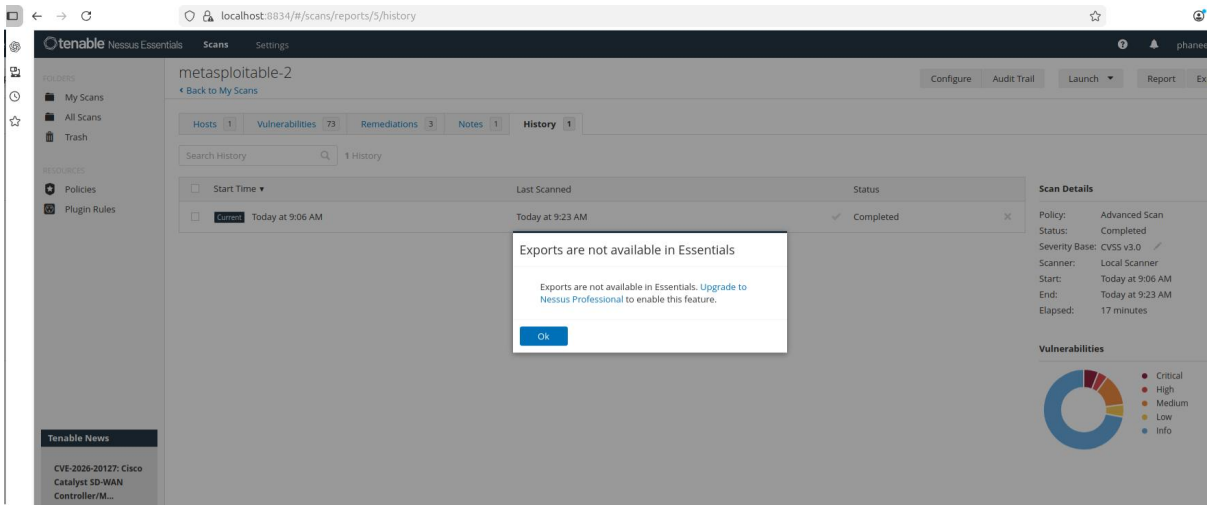
Installing nessus on ubuntu and configuring the nessus and performing a basic vulnerability scanning to the metasploitabale in my virtual lab environment.



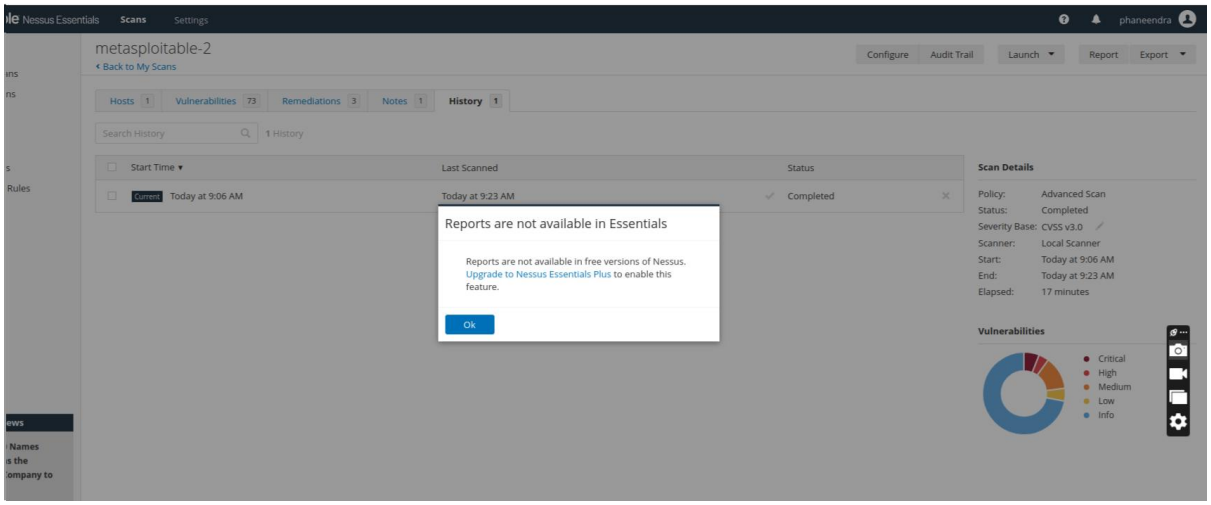
The vulnerability scan is completed and obtained low level to critical level vulnerabilities



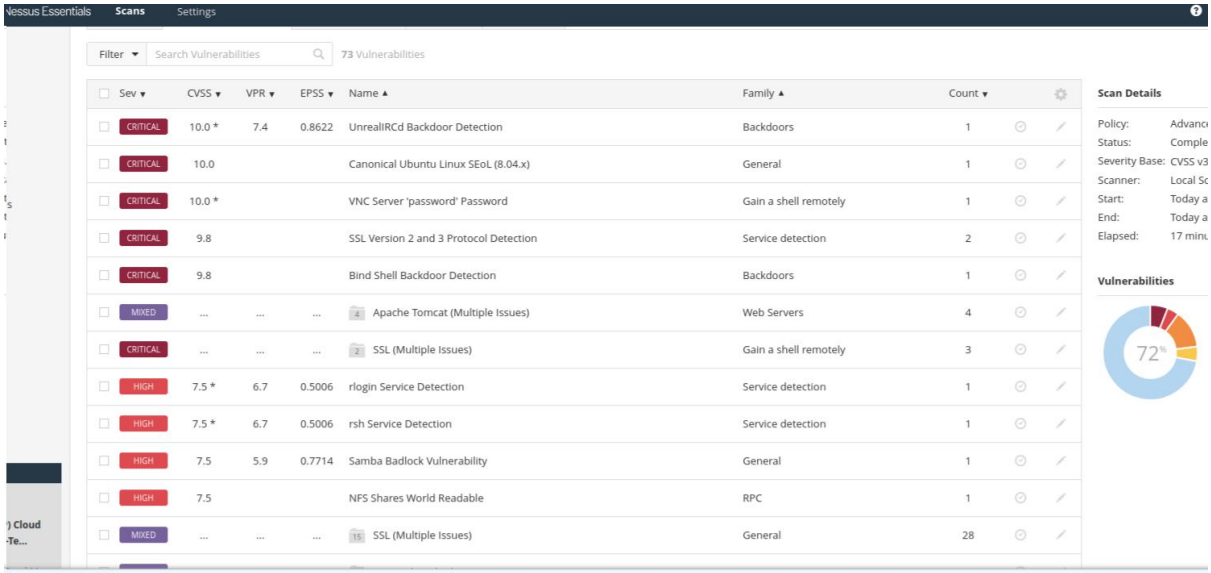
In normal nessus there is no export facility available to export the report. In Premium nessus essentials contains many featues and tools to perform scanning at very low level of the computer system.



Reports also not available to see in normal basic nessus tool



Scanned vulnerabilities based on cvss score



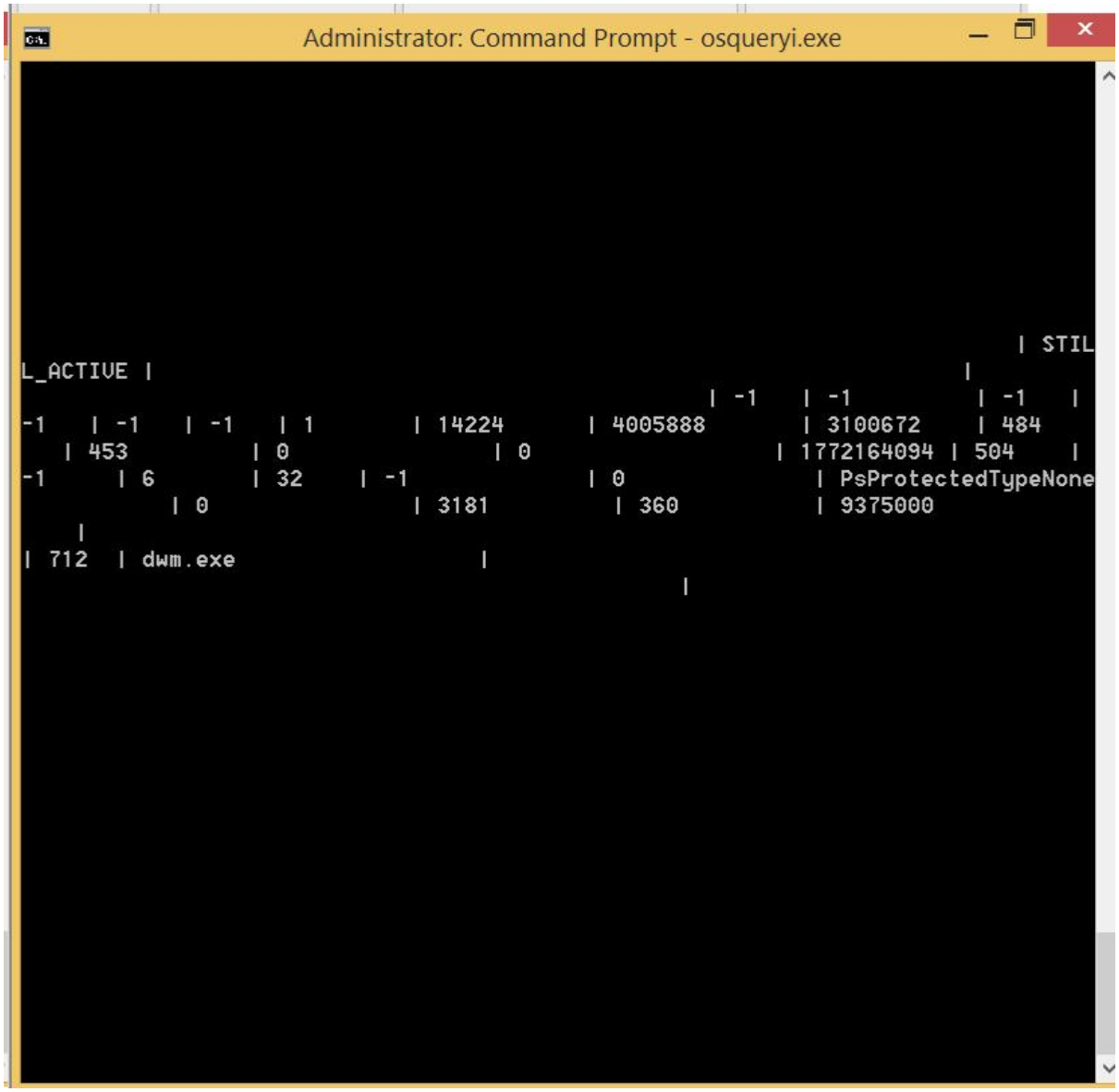
Based on cvss score the top 3 vulnerabilities the score is 10.0 and the type of vulnerabilities is

OSQUERY

Downloaded osquery from their official website and configuring it and running from cmd adminstrator.

Executed via SQL syntax process here I used command

SELECT * FROM processes;



5. Basic Security Concepts

CIA Triad:

The CIA triad is the foundation of information security.

1. Confidentiality:-

Only the authorized persons can access the data. Preventing unauthorized access to data.

Controls:

- Encryption (AES,TLS)
- Acess control
- Data masking

Example : only HR should access the salary data.

If a hacker can access the sallary data . then, it will leads to data breach.

2. Integrity :-

Ensuring data is accurate and not altered. Only authorized persons can modify the data.

Controls:

- Hashing (SHA-256)
- Digital signatures
- File integrity monitoring

Example: Bank balance should not change without a valid transaction.

Attacker modifies exam marks in the database.

3. Availability :-

Systems and data must be accessible when needed. Ensure that storing,retrieving and modifying is possible by only authorized persons.

Controls:

- Redundancy
- Backups
- Load balancing
- DDoS protection

Example: Website down due to DDoS leads to availability breach.

Threat vs Vulnerability vs Risk :-

1. Threat

Anything that can cause harm.

Example:

- Hacker
- Malware
- Insider
- Natural disaster

2. Vulnerability

Exploitation of system weakness for controlled access.

Examples :

- Unpatched software
- Weak password
- Open port

3. Risk

The potential damage when a threat exploits a vulnerability.

Risk = Threat × Vulnerability × Impact

Threat → Attacker
Vulnerability → Outdated Apache server
Risk → Website compromise

4. Defense-in-Depth

Defence in depth is a Layered security approach.

Firewall
↓
IDS/IPS
↓
Endpoint Security
↓
Access Control
↓
Encryption

If one layer fails, others protect.

Example: Even if attacker bypasses firewall → EDR detects malware.

5. Zero Trust Model

It is “Never trust, always verify.”

- Even inside the network.
- Continuous authentication
- Least privilege access
- Micro-segmentation
- Device posture validation

Example: Even internal employee must use MFA.

Case study :
In 2017 the massive data breach happened from Equifax . in this breach lots of user data has breached.

- Apache Struts vulnerability (CVE-2017-5638)
- Patch available
- 147 million records leaked

Lesson: Vulnerability + No patching = Massive risk

This is a failure of:
- Vulnerability management
- Asset tracking
- Risk assessment

6. Security Operations Workflow

Security Operations Workflow (SOC Lifecycle)

A SOC follows a structured incident handling lifecycle:

Detection → Triage → Investigation → Response → Lessons Learned

1. Detection Phase

- Security tools generate alerts.
- SIEM (Splunk, QRadar)
- EDR (CrowdStrike, Defender)
- IDS/IPS (Snort, Suricata)

Email security gateway
Example Alerts:
- Suspicious PowerShell execution
- Multiple failed logins
- Phishing email detected
- Malware hash match

At this stage: You only know something suspicious happened.

2. Triage Phase

Determine:
1 Is it real?
2 Is it serious?
3. What is the impact?

Actions:
- Check severity score
- Check affected user/system
- Check asset criticality
- Validate false positive

Example
Priority
1. Critical - Domain controller compromised - P1
2. High- Ransomware behavior- P1
3. Medium- Malware detected- P2
4. Low - Single failed login- P3

Triage answers:
Is it a false positive?
What priority should it be?

3. Investigation Phase

Investigating the alert
Tasks:
- Log correlation
- IOC search (IP, hash, domain)
- Process tree analysis
- Timeline reconstruction

Tools:
- SIEM query
- Osquery
- VirusTotal
- EDR console

Questions to Ask to victim or effected system control measures
1. How did it start?
2. What process executed?
3. Was there lateral movement?

4. Any data exfiltration?
5.

Investigation builds the full attack story.

5. Response Phase

If the attack is as confirmed malicious then the response phase contains three controlled stages.

❖ **Containment:-**

- Isolate endpoint
- Block IP/domain
- Disable user account

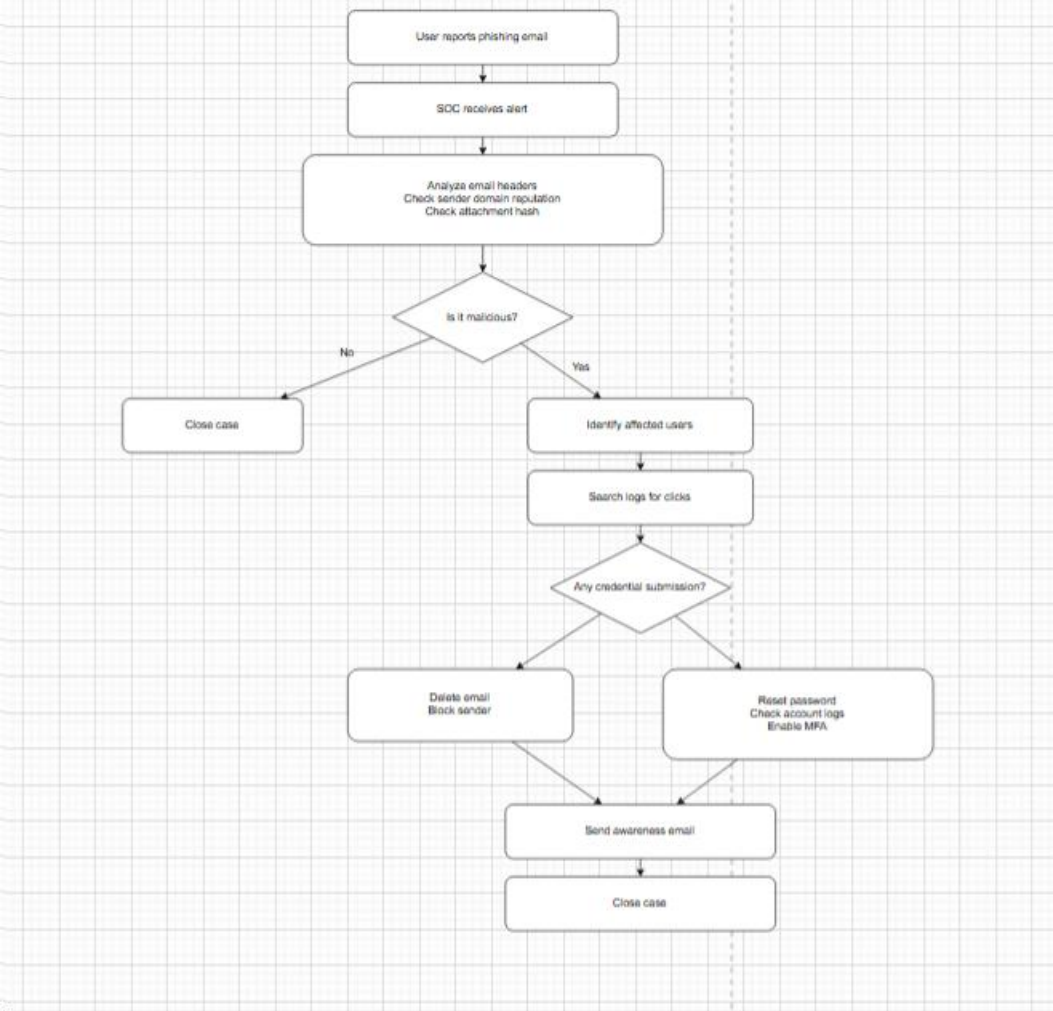
❖ **Eradication:-**

- Remove malware
- Patch vulnerability
- Reset credentials

❖ **Recovery:-**

- Restore from backup
- Monitor systems

Flowchart of a phishing email incident



7. Incident Response

According to National Institute of Standards and Technology (NIST SP 800-61), the IR lifecycle has six structured phases:

Preparation → Identification → Containment → Eradication → Recovery → Lessons Learned

1. Preparation

Be ready before an incident happens.

- Define IR policy
- Create incident response team
- Deploy SIEM, EDR, IDS
- Backup strategy
- Patch management
- Logging & monitoring
- Run tabletop exercises

Example:

1. Enable MFA
2. Configure SIEM alerts
3. Document escalation matrix

If preparation fails → response becomes chaotic.

2. Identification

Confirm whether an event is a security incident.

- SIEM alert
- User complaint
- EDR detection
- External notification

1. Validate alert
2. Determine scope
3. Identify affected assets
4. Classify severity

Example: EDR flags suspicious PowerShell → analyst verifies malicious behavior

.

3. Containment

Limit damage and prevent spread.

Two types:

Short-Term Containment

- Isolate host
- Disable account
- Block IP

Long-Term Containment

- Apply temporary fixes
- Network segmentation
- Patch vulnerability

Example: In ransomware: Disconnect infected machine immediately.

4. Eradication

Remove the root cause.

- Delete malware
- Remove persistence (registry, scheduled tasks)
- Patch exploited vulnerability
- Reset credentials
- Remove backdoors

Example: Remove malicious service + patch SMB vulnerability.

5. **Recovery**

Restore operations safely.

- Restore from backups
- Reconnect to network
- Monitor for reinfection
- Validate system integrity

Example: Restore encrypted files from clean backup.

6. Lessons Learned

Improve security posture.

- Post-incident review meeting
- Root cause analysis
- Update detection rules
- Improve controls
- Staff awareness training

Example: Add email filtering rule after phishing incident.

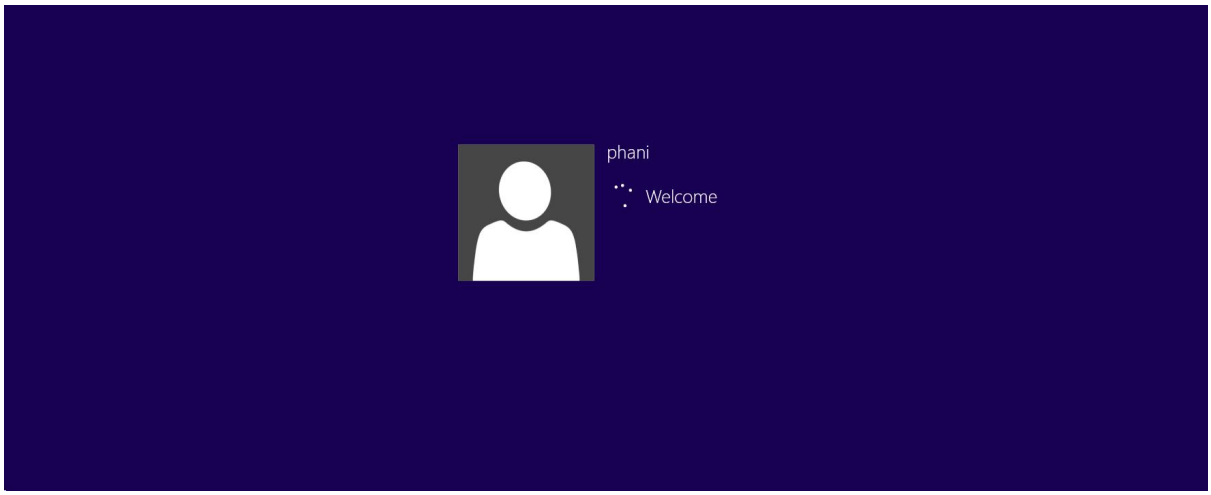
Practical Application:

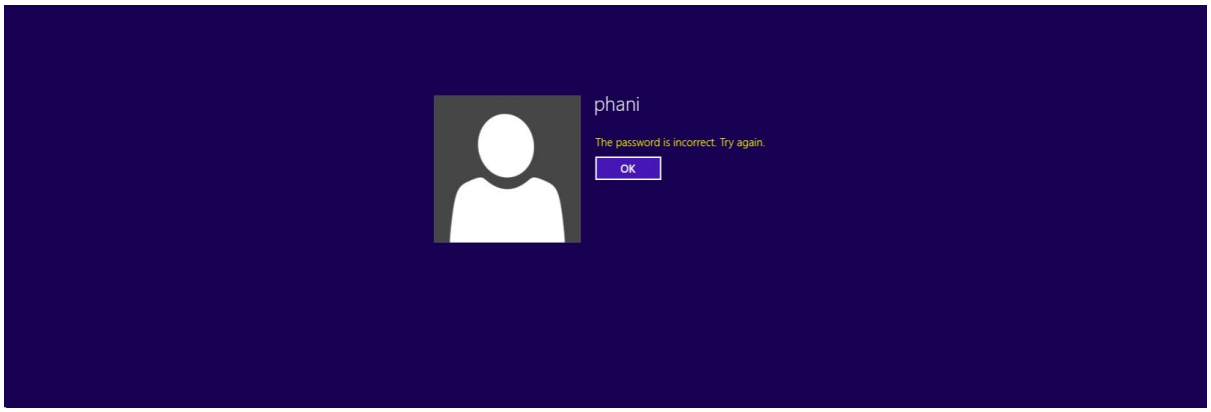
1. Log analysis Practice

- Windows Event Viewer

Identifying bruteforce attack attempts using Event ID 4625.

For this, I'm going to give wrongh passwords in the windows VM

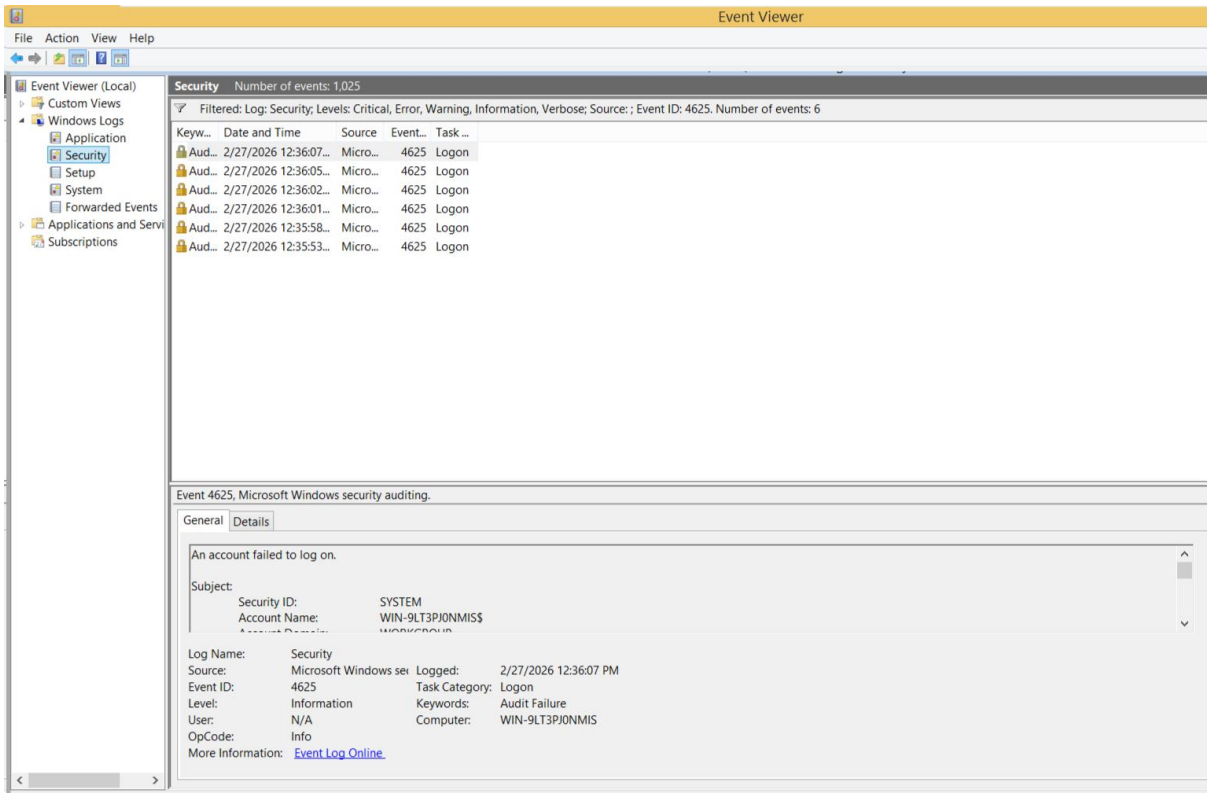




After this failed login attempts going to see the failed login attempts in the windows logs by using this process

1. Win + R
2. Typing eventvwr.msc
3. Selecting windows logs
4. Selecting security
5. Filtering event 4625

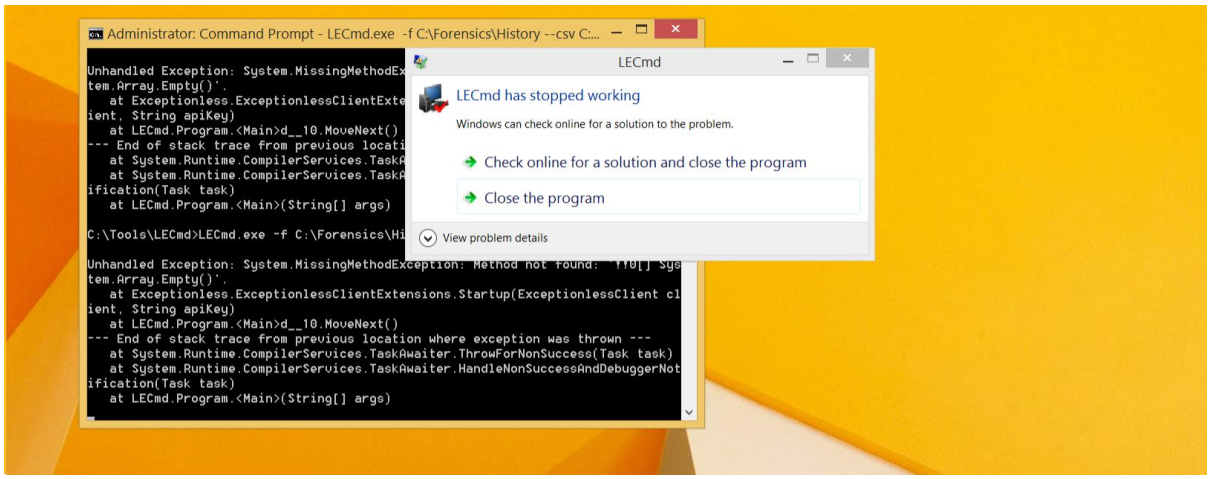
And then hitting enter



6 failed login attempts occurred with event ID 4625

Browser History Analysis by using zimmermans tools

Zimmerman forensic tool LECmd is not working properly in my windows VM.



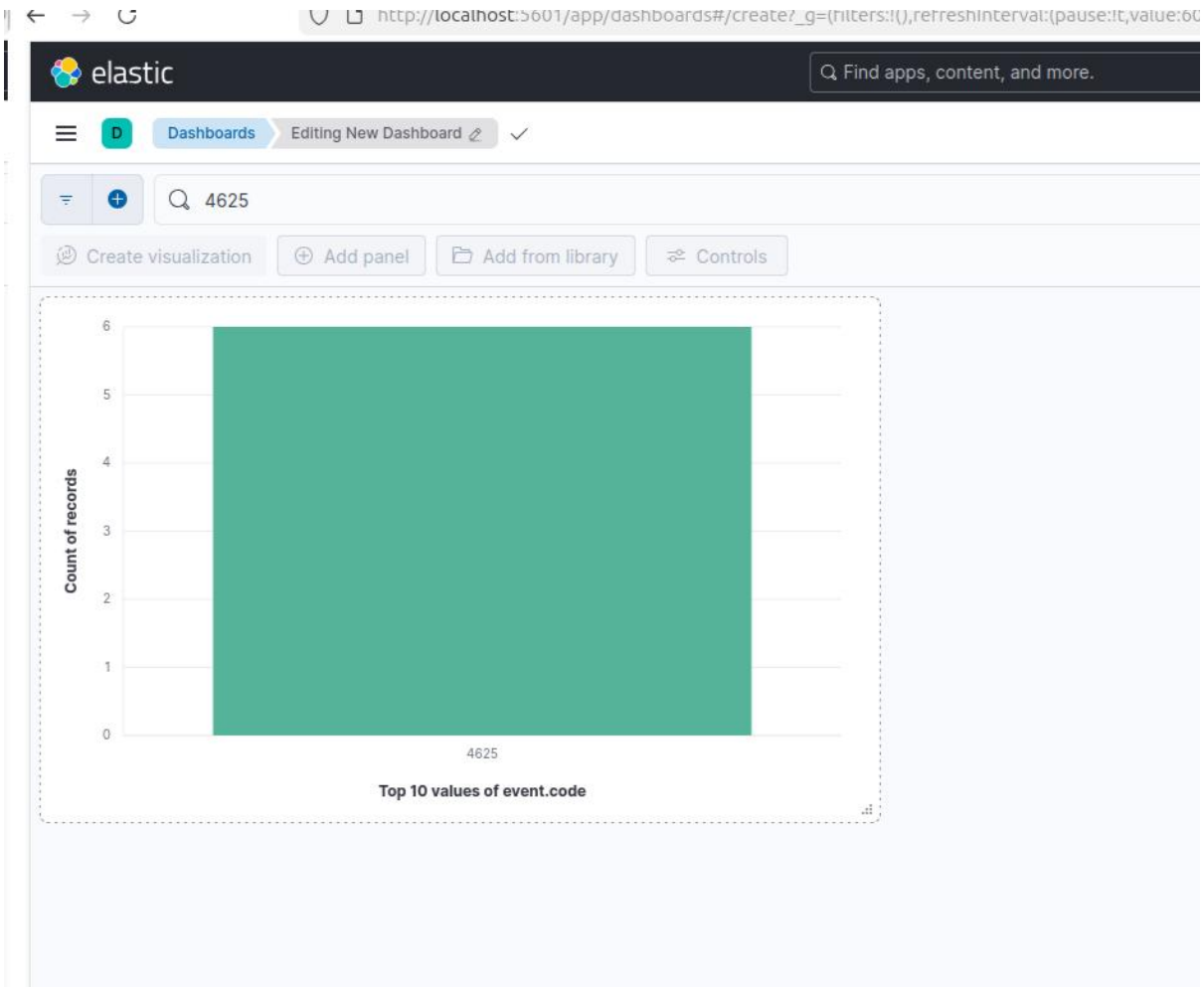
2. Document Security Events

Here, I'm documenting the bruteforce scenario of multiple failed login attempts

Date/Time	Source Network Address	Event ID	Failure Reason	Action Taken
27-02-2026 11:34	192.168.127.130	4625	multiple failed login attempts detected for user "rocky"	investigated source IP. confirmed it was internal test activity. No malicious intent found.
27-02-2026 11:43	192.168.127.139	4624	successful failed attempt	

3. Setup Monitoring Dashboards

In kibana, creating a visualization of top 10 source ips generating alerts of 4625



4. ColnfIgure alert Rules

While configuring detection rules in Elastic SIEM, the system displayed permission and detection engine requirement errors. Investigation confirmed that advanced detection rule features are restricted under the Basic (free) license.

Conclusion :-

Today I worked on configuring Elastic SIEM, troubleshooting authentication and connectivity issues, and understanding how detection rules function. I explored how to create a threshold-based alert for multiple failed login attempts and learned the importance of proper security configuration for enabling SIEM features. This session improved my understanding of log monitoring, alert logic, and real-world SOC workflow.